

Implementing a Layered Email Security Solution to Mitigate Phishing Attacks at Yummy Pretzel Co.

A. Security Problem Under Investigation

A1. Importance and Background of the Security Problem

Yummy Pretzel Co. is a fictional, mid-sized food manufacturing organization headquartered in the United States. The organization employs approximately 350 employees across three locations and relies heavily on electronic communications to conduct business with suppliers, distributors, customers, financial institutions, and business partners. The company's technology environment consists primarily of Windows-based employee workstations, Microsoft 365 for email and productivity services, cloud-based business applications, networked file storage, and centralized identity and access management. Because employees regularly communicate with external organizations, email represents an important component of the company's business operations and a significant potential attack surface.

The cybersecurity problem under investigation is a successful phishing attack that resulted in a malware infection and unauthorized access to Yummy Pretzel Co.'s corporate environment. The attack began when an employee in the sales department received an email that appeared to originate from a legitimate competing company. The message presented a potential business opportunity and included an attachment that appeared to contain information related to the proposed partnership. The email was fraudulent, and the attachment contained malware.

The employee opened the attachment, allowing the malicious software to execute on the workstation. Following execution, the malware established unauthorized communication with an external command-and-control infrastructure, giving the attacker access to information available to the compromised user account. The attacker subsequently accessed internal resources and exfiltrated proprietary business information and personally identifiable information (PII) of employees, including dates of birth, Social Security numbers, and financial account information.

The incident negatively affected Yummy Pretzel Co. in several areas. The compromise created confidentiality risks because an unauthorized party accessed sensitive employee and business information. It also created operational risks because the affected workstation had to be removed from the production environment while the security team investigated and remediated the malware. In addition, the organization incurred incident-response costs, required additional information technology personnel, and faced potential reputational and legal consequences from the exposure of employee information.

The problem is significant because phishing attacks continue to represent a substantial source of organizational compromise. Microsoft's 2025 Digital Defense Report reported that 28% of breaches analyzed by Microsoft Incident Response were initiated through phishing or social

engineering (Microsoft, 2025). The same report identifies data theft as a major attacker motivation and describes the increasing sophistication and scale of social-engineering attacks. Verizon's 2025 Data Breach Investigations Report similarly identified a continuing high level of human involvement in breaches and emphasized the relationship between social engineering and credential abuse (Verizon, 2025).

For Yummy Pretzel Co., the incident demonstrates that reliance on a single security layer is insufficient to protect an organization against email-based attacks. A successful phishing message reached an employee; the malicious attachment was executed, malware gained a foothold on an endpoint, and the attacker subsequently accessed sensitive information. The implementation, therefore, focuses on establishing multiple technical layers to prevent, detect, and contain similar attacks.

A2. Documentation Demonstrating the Need for a Solution

Real-world cybersecurity research supports the need for Yummy Pretzel Co. to address phishing as a significant organizational risk. Microsoft's 2025 Digital Defense Report identifies phishing and social engineering as major initial access techniques and notes that threat actors continue to develop increasingly sophisticated methods to convince users to interact with malicious content (Microsoft, 2025). The report further explains that modern threat actors are combining social engineering with multi-stage attack techniques, increasing the potential consequences of a successful phishing interaction.

The Verizon 2025 Data Breach Investigations Report provides additional evidence of the relationship between human behavior and successful cybersecurity incidents. Verizon reported that human involvement remains a significant component of breaches and identified social engineering as an important attack pattern (Verizon, 2025). These findings apply to Yummy Pretzel Co. because the fictional incident similarly begins with an employee interacting with a fraudulent communication.

The Cybersecurity and Infrastructure Security Agency (CISA) also identifies phishing emails containing malicious links or attachments as a common method for conducting malicious cyber activity. CISA recommends that organizations take measures to reduce the likelihood and impact of successful phishing attacks (Cybersecurity and Infrastructure Security Agency [CISA], 2024).

Together, these sources demonstrate that the phishing scenario experienced by Yummy Pretzel Co. represents a realistic organizational cybersecurity problem rather than an isolated or unlikely event. The external evidence supports the decision to implement layered technical controls to address email authentication, malicious message detection, endpoint protection, and unauthorized account access.

A3. Root Causes of the Security Problem

The primary root cause of the incident was insufficient layered protection against phishing-based attacks. Several contributing causes allowed the initial phishing message to progress into a broader security incident.

Insufficient email authentication. Yummy Pretzel Co. did not have sufficiently restrictive email authentication controls to prevent an attacker from impersonating a legitimate business organization. Weak or incomplete implementation of SPF, DKIM, and DMARC allowed the fraudulent communication to appear more credible to the recipient.

Insufficient email filtering. The organization's existing email security configuration did not identify and quarantine the malicious attachment before it reached the employee's inbox. The absence of sufficiently aggressive attachment analysis and malicious-content filtering contributed to the initial compromise.

Endpoint protection limitations. The employee workstation did not prevent the malicious attachment from executing. Existing endpoint security controls either failed to detect the malware or did not automatically isolate the workstation quickly enough to prevent additional unauthorized activity.

Excessive reliance on employee judgment. The attack relied on social engineering to convince an employee that the fraudulent email was legitimate. Although employee behavior contributed to the incident, the root cause was not solely employee error. The security architecture did not provide sufficient technical controls to prevent a single user interaction from developing into a significant compromise.

Insufficient defense-in-depth. The organization lacked sufficient layers of preventive and detective controls between the employee's inbox, endpoint, identity infrastructure, and sensitive data. Consequently, a single successful phishing interaction could progress from email delivery to malware execution and unauthorized data access.

B. Internal and External Project Stakeholders

Implementing the layered email security solution requires participation from multiple internal and external stakeholders. Each stakeholder has different responsibilities, needs, and levels of influence over the project's objectives and outcomes.

Chief Information Officer

The Chief Information Officer (CIO) serves as the executive sponsor for the project. The CIO provides executive authorization, approves major expenditures, resolves organizational conflicts, and ensures that the implementation aligns with business objectives. The phishing incident affects the CIO because it poses organizational risks to business continuity, financial resources, regulatory obligations, and corporate reputation. The CIO's primary need is assurance that the implemented solution provides measurable risk reduction without creating unacceptable

operational disruption. The CIO has significant influence over the project's outcomes because executive approval is required for funding, staffing, and organizational adoption.

Information Security Manager

The Information Security Manager is responsible for directing the cybersecurity aspects of the implementation. This stakeholder evaluates security requirements, approves security configurations, coordinates risk assessments, and validates that the solution addresses the identified threat. The phishing incident directly affects the Information Security Manager because the event demonstrates weaknesses in the organization's preventive and detective security capabilities. The manager needs effective security controls, reliable monitoring capabilities, and measurable security outcomes. This stakeholder has substantial influence over project objectives because the Information Security Manager determines whether the technical implementation adequately addresses the identified cybersecurity risks.

Security Operations Center Analysts

SOC analysts are responsible for monitoring security alerts, investigating suspicious activity, and responding to potential incidents. The phishing attack increases the SOC's workload because malicious email activity, malware alerts, endpoint detections, and potentially compromised accounts require investigation. SOC analysts need accurate alerts, sufficient endpoint visibility, and centralized security telemetry. Their feedback influences the configuration of detection and response controls, thereby directly affecting the project's ability to detect future phishing-related activity.

Systems Administrator

The Systems Administrator is responsible for configuring and maintaining servers, endpoints, identity services, and security software. The stakeholder is affected by the incident because the compromised workstation required investigation, isolation, remediation, and restoration. The Systems Administrator needs clear technical requirements, deployment procedures, maintenance windows, and compatibility information. This stakeholder influences the implementation by ensuring that security controls can be deployed without negatively affecting existing systems.

Network Administrator

The Network Administrator is responsible for network connectivity, segmentation, firewall configuration, and network-level security controls. The phishing incident affects this stakeholder because malware may establish outbound communications with attacker-controlled infrastructure. The Network Administrator needs accurate information regarding expected network traffic, security policies, and potential indicators of compromise. The stakeholder influences the project by implementing network controls that can restrict malicious communications and limit the potential movement of compromised systems.

Messaging/Email Administrator

The Messaging Administrator is responsible for the organization's email environment and will handle much of the technical configuration for the solution. The stakeholder is directly involved in configuring S/MIME, SPF, DKIM, DMARC, email filtering rules, quarantine policies, and email security settings. The administrator needs appropriate administrative permissions, vendor documentation, testing environments, and defined change-control procedures. Because email configuration errors can disrupt legitimate business communication, this stakeholder has significant influence over the successful deployment and validation of the solution.

Incident Response Team

The Incident Response Team is responsible for handling future phishing-related security incidents. The team is affected by the existing problem because successful phishing attacks increase incident volume and require endpoint isolation, malware removal, evidence collection, and recovery activities. The team needs sufficient logging, endpoint telemetry, alerting, and documented technical procedures. The team's feedback will influence the configuration of detection and containment capabilities.

Email Security Vendor

The external email security vendor provides the technology platform, technical documentation, product support, and implementation assistance required for the Secure Email Gateway component. The vendor is not responsible for Yummy Pretzel Co.'s internal security decisions but provides the expertise necessary for successful deployment. The vendor needs accurate technical requirements and information about the organization's email environment. The vendor influences project outcomes through product capabilities, configuration recommendations, and technical support.

Microsoft 365 Support or Consulting Partner

A Microsoft 365 support or consulting partner may aid with Microsoft 365 email configuration, identity management, authentication, and integration with endpoint security technologies. The stakeholder is necessary because changes to cloud-based email and identity services can affect a large portion of the organization's workforce. The partner's technical recommendations and implementation support influence the stability and compatibility of the final solution.

C. Historical Data Used to Support Decision-Making

Because Yummy Pretzel Co. is a fictional organization, the historical data used for this project will consist of simulated organizational records representing information that would reasonably exist within the company's environment. These records will be used to support implementation decisions rather than presented as actual data from a real organization.

The first source of historical data will be the organization's previous phishing and security incident records. These records will identify the number and types of phishing messages reported by employees, the number of malicious attachments detected, the number of compromised endpoints, and the amount of time required to investigate and remediate previous incidents.

Email gateway and Microsoft 365 message-trace data will also be reviewed. These records will provide information about suspicious senders, malicious attachments, email authentication failures, quarantine events, and previously blocked messages. This information will help determine which email security rules should be implemented.

Endpoint Detection and Response records will be used to examine previous malware detections, suspicious processes, endpoint isolation events, and malware-related alerts. These records will establish a baseline for evaluating whether the new endpoint security configuration improves detection and response capabilities.

Vulnerability scan results will be reviewed to identify weaknesses on employee workstations and supporting infrastructure. The results will be used to determine whether endpoint vulnerabilities could increase the impact of a successful phishing attack.

The organization will also review previous audit results, incident tickets, security assessments, and access-control records. These sources will help identify recurring weaknesses and determine whether existing security controls have been consistently configured.

Finally, phishing simulation results will be used to establish an employee interaction baseline. The simulations will measure metrics such as message-open rates, attachment interaction rates, link-click rates, and phishing-reporting rates. NIST's Phish Scale provides a standardized approach for evaluating the difficulty of phishing messages used in awareness and simulation programs (Dawkins & Jacobs, 2023).

These historical data sources will provide evidence to support security control decisions and establish baseline measurements for comparison with post-implementation results.

D. Project Requirements

The implementation of the layered email security solution requires technical, personnel, financial, operational, and organizational resources. The requirements are designed to ensure that the new controls can be deployed without creating unacceptable business disruption.

Technical Requirements

The technical requirements include an email platform that supports S/MIME and modern email authentication technologies, a Secure Email Gateway that analyzes malicious messages and attachments, and Endpoint Detection and Response capabilities for employee workstations. The

implementation also requires DNS administration capabilities for configuring SPF, DKIM, and DMARC.

Multi-Factor Authentication will be enabled for organizational accounts to reduce the risk associated with compromised credentials. The solution will also require centralized logging and monitoring capabilities so that security personnel can identify suspicious authentication attempts, malware detections, email security events, and endpoint activity.

The organization will maintain a controlled testing environment for validating security configurations before production deployment. Test systems will be used to verify email delivery, authentication, malware detection, endpoint isolation, and alert generation.

Hardware Requirements

The project will use the organization's existing employee workstations and network infrastructure where technically feasible. Additional hardware is not expected to be required for cloud-based email security services. Network infrastructure must support the required security policies and traffic-monitoring capabilities.

Software Requirements

The primary software requirements include:

- S/MIME-compatible email capabilities
- Secure Email Gateway technology
- Endpoint Detection and Response software
- Microsoft 365 security and administrative capabilities
- Multi-Factor Authentication
- DNS management for SPF, DKIM, and DMARC
- Centralized security logging and monitoring
- Phishing simulation software
- Vulnerability scanning capabilities

Personnel Requirements

The project requires participation from the CIO, Information Security Manager, SOC analysts, Systems Administrator, Network Administrator, Messaging Administrator, Incident Response Team, and external technology vendors. Personnel will be assigned according to the implementation phase and will participate in planning, configuration, testing, validation, and project closure.

Financial Requirements

The project will require funding for email security software or licensing, endpoint security licensing, S/MIME certificates, implementation support, personnel labor, testing resources, and employee training. Because Yummy Pretzel Co. is a fictional organization, final vendor pricing

will be determined using current vendor quotations and published pricing information during the detailed budgeting stage of the project.

Operational Requirements

The implementation must minimize disruption to normal business operations. Email delivery and business communications are considered critical services, so configuration changes will initially be performed in a controlled testing environment and subsequently introduced through a phased production rollout. Maintenance windows will be established for changes that could affect email delivery or endpoint availability.

Security and Compliance Requirements

The implementation will be aligned with NIST Cybersecurity Framework (CSF) 2.0 and applicable NIST security controls. NIST CSF 2.0 provides organizations with a structured approach to managing cybersecurity risk and can be applied across organizations of different sizes and sectors (Pascoe et al., 2024). NIST SP 800-53 Rev. 5 will also be used as a reference for security and privacy controls related to access control, identification and authentication, audit and accountability, incident response, system and communications protection, and system and information integrity (National Institute of Standards and Technology [NIST], 2020).

Because the fictional organization processes employee PII, the project will also incorporate appropriate privacy and data-protection considerations. The implementation will not assume that a specific industry regulation applies unless the fictional organization's business operations establish such a requirement.

D1. Industry-Standard Methodologies Guiding Solution Design and Development

The solution will be designed using the NIST Cybersecurity Framework (CSF) 2.0 as the primary cybersecurity risk-management framework. NIST CSF 2.0 provides a flexible structure for organizations to understand, assess, prioritize, and communicate cybersecurity risks (Pascoe et al., 2024).

The implementation will use the CSF 2.0 Functions of Govern, Identify, Protect, Detect, Respond, and Recover to organize security activities. The Governance and Identity Functions will support understanding the organization's cybersecurity requirements and risks. The Protect Function will guide implementation of preventive controls such as email authentication, MFA, and endpoint protection. The Detect Function will support email and endpoint monitoring. The Respond Function will support incident investigation and containment. The Recovery Function will address restoration of affected systems and lessons learned.

NIST SP 800-53 Rev. 5 will supplement CSF 2.0 by providing a catalog of security and privacy controls applicable to areas such as access control, identification and authentication, audit and accountability, incident response, system and communications protection, and system and information integrity (NIST, 2020).

NIST SP 800-61 Rev. 3 will also inform the incident-response component of the implementation. NIST finalized Revision 3 in 2025 and describes incident response as an integrated component of cybersecurity risk management, supporting the organization's ability to detect, respond to, and recover from cybersecurity incidents (NIST, 2025).

These standards provide the project with recognized industry guidance while allowing the controls to be tailored to the fictional environment of Yummy Pretzel Co.

D2. Project Launch, Rollout Phases, and Project Management Methodology

The project will use a **Waterfall project management methodology**. Waterfall was selected because the implementation requires clearly defined requirements, sequential technical dependencies, formal change control, testing, and documented approval before moving between major implementation phases. Email security configuration can affect the availability of a critical business communication system; therefore, a structured implementation process will reduce the risk of uncontrolled production changes.

The project will begin with a formal project kickoff involving the executive sponsor, project manager, Information Security Manager, technical administrators, and external vendors. During the kickoff, project scope, responsibilities, implementation requirements, milestones, communication procedures, and success criteria will be reviewed and approved.

Phase 1: Project Initiation and Planning

The first implementation phase will establish the project baseline. The project team will confirm the scope, objectives, stakeholders, technical requirements, implementation schedule, and resource requirements. Existing documentation and historical security data will be collected and reviewed.

The phase will conclude when the executive sponsor has approved the project charter, requirements, stakeholder assignments, and implementation schedule.

Phase 2: Security Assessment and Baseline Development

The project team will assess the existing email and endpoint security environment. Historical phishing incidents, email logs, endpoint security records, vulnerability scan results, audit findings, and incident tickets will be reviewed.

A baseline will be established for phishing detection, handling malicious attachments, endpoint malware detection, authentication security, and incident response. The baseline will provide measurements against which the implemented solution can be evaluated later.

The phase will conclude when the security assessment is complete, and the technical requirements for implementation are approved.

Phase 3: Solution Design and Configuration

The technical team will design the target security architecture. Configuration requirements for S/MIME, SPF, DKIM, DMARC, Secure Email Gateway filtering, EDR, MFA, logging, and alerting will be documented.

The team will first configure the controls in a controlled testing environment. Email authentication records will be validated before production DNS changes are introduced. Endpoint security policies will be configured to detect malicious files and suspicious activity without unnecessarily disrupting legitimate business applications.

The phase will conclude when all technical configurations have passed initial configuration review and are ready for controlled testing.

Phase 4: Pilot Implementation

The security controls will initially be deployed to a limited group of users representing different business functions. The pilot group will enable the project team to identify compatibility issues, false positives, email delivery problems, endpoint performance issues, and authentication failures before organization-wide deployment.

The project team will monitor email delivery, security alerts, endpoint performance, and user-impact reports throughout the pilot.

The phase will conclude when the pilot group demonstrates stable operation, and all critical issues have been resolved or formally accepted as residual risks.

Phase 5: Production Rollout

After successful pilot validation, the technical team will deploy the approved security controls across the organization's production environment. Deployment will occur in controlled groups rather than simultaneously across all employees.

The Messaging Administrator will implement the approved email authentication and filtering configurations. The Systems Administrator will deploy endpoint security policies. The Network

Administrator will validate required network communication and security controls. SOC analysts will monitor security alerts during the rollout.

The production rollout will conclude when all designated systems and users have received the required security configurations, and the implementation team confirms that normal business operations have not been negatively affected.

Phase 6: Validation and Security Testing

Following production deployment, the project team will conduct validation testing using controlled phishing scenarios and technical test cases. Testing will verify whether malicious messages are detected or blocked, whether malicious attachments are prevented from executing, whether endpoints generate appropriate alerts, and whether compromised systems can be isolated.

The team will also verify SPF, DKIM, and DMARC behavior using legitimate and simulated unauthorized messages. Authentication and access-control testing will verify that MFA is functioning correctly.

The phase will conclude when all mandatory acceptance criteria have been satisfied and critical implementation defects have been remediated.

Phase 7: Project Closure and Transition to Operations

The final phase will transition the implemented security controls from the project team to normal IT and security operations. Configuration documentation, administrative procedures, monitoring requirements, testing results, and unresolved risks will be documented.

The project manager will conduct a final review with the executive sponsor and the Information Security Manager. Lessons learned will be recorded and incorporated into future security improvements.

The implementation will be considered complete when the approved security controls are operational, validation testing has met the defined acceptance criteria, documentation has been completed, operational ownership has been transferred, and the project sponsor has approved project closure.

D3. Implementation Risks, Likelihood, and Impact

The implementation of the phishing security solution at Yummy Pretzel Co. presents several risks that could affect the project's schedule, cost, technical performance, or ability to meet its

security objectives. The primary implementation risks include configuration errors, compatibility issues, employee resistance, disruption of legitimate business communications, insufficient testing, certificate management issues, and resource or budget constraints. Each risk was evaluated based on its likelihood of occurrence and its potential impact on the project.

Security-control misconfiguration

Security-control misconfiguration is considered a medium-likelihood, high-impact risk. The project requires configuring Microsoft Defender for Office 365, Microsoft Defender for Endpoint, Microsoft Entra ID, MFA, and S/MIME. Incorrect configurations could result in legitimate emails being blocked, malicious messages being allowed, endpoints not being properly monitored, or authentication controls being applied incorrectly. A significant configuration error could reduce the security solution's effectiveness and require additional implementation time. To reduce this risk, configuration changes will be performed in a controlled testing environment before deployment to production. Configuration settings will also be validated during the project's formative testing phase.

Compatibility and interoperability issues

Compatibility and interoperability issues are considered a medium-likelihood, medium-impact risk. Yummy Pretzel Co. will implement multiple security technologies that must operate within the organization's existing Microsoft 365 environment. Incompatible configurations could cause problems with email delivery, authentication, endpoint protection, or S/MIME functionality. These issues could delay deployment and require additional technical support. The project will mitigate this risk by conducting compatibility testing before full deployment and implementing the solution in controlled phases.

Disruption to legitimate email communications

Disruption to legitimate email communications is considered a medium-likelihood, high-impact risk. More aggressive email security settings could incorrectly identify legitimate business messages as phishing attempts or malicious content. This could interfere with communications between employees, customers, vendors, and business partners. Such disruptions could affect productivity and business operations. The organization will mitigate this risk by testing email security policies before production deployment, monitoring quarantine activity, establishing procedures for reviewing false positives, and adjusting security configurations as necessary.

Employee resistance or lack of participation

Employee resistance or lack of participation is considered a medium-likelihood, medium-impact risk. The project requires employees to complete security awareness training, participate in phishing simulations, use MFA, and follow new procedures for reporting suspicious messages. Some employees may view these requirements as inconvenient or unnecessary. Low participation could reduce the effectiveness of the overall security solution and prevent the organization from achieving its phishing-risk reduction objectives. Management support,

communication of the project's purpose, mandatory training requirements, and recurring phishing simulations will be used to reduce this risk.

Insufficient testing before production deployment

Insufficient testing before production deployment is considered a low-likelihood, high-impact risk. If the organization does not adequately test the security controls before deployment, configuration problems may not be discovered until the solution is operating in the production environment. This could result in security gaps or business disruption. The project will address this risk through formative testing of individual controls followed by summative testing of the complete solution. Test cases will include malicious attachment detection, malicious URL detection, endpoint malware detection and isolation, MFA enforcement, S/MIME functionality, and simulated phishing attacks.

S/MIME certificate deployment issues

S/MIME certificate deployment issues are considered a medium-likelihood, medium-impact risk. S/MIME requires certificates to be properly issued, installed, configured, and maintained. Incorrect certificate deployment could prevent users from sending or receiving encrypted or digitally signed messages. Expired or improperly managed certificates could also interrupt secure email communications. The project will mitigate this risk through controlled certificate deployment, documented installation procedures, certificate inventory, and monitoring of certificate expiration dates.

Insufficient project resources

Insufficient project resources are considered a medium-likelihood, medium-impact risk. The project requires funding for Microsoft security technologies, S/MIME certificates, security awareness training, phishing simulations, consulting assistance, and testing resources. Unexpected implementation requirements could increase project costs or require additional personnel. The project will address this risk through the project budget established in Task 2, documented resource requirements, phased implementation, and regular monitoring of project expenditures.

Implementation delays

Implementation delays are considered a medium-likelihood, medium-impact risk. Delays could occur due to vendor configuration requirements, certificate issuance, employee training schedules, testing issues, or IT personnel availability. Delays could cause the project to exceed its planned completion date and affect other project activities. The project will use phased implementation and milestone tracking to identify delays early and enable corrective action.

Risk Summary

Implementation Risk	Likelihood	Impact	Overall Risk
Security-control misconfiguration	Medium	High	High
Compatibility/interoperability issues	Medium	Medium	Medium
Disruption to legitimate email	Medium	High	High
Employee resistance/lack of participation	Medium	Medium	Medium
Insufficient pre-production testing	Low	High	Medium
S/MIME certificate deployment issues	Medium	Medium	Medium
Resource/budget constraints	Medium	Medium	Medium
Implementation delays	Medium	Medium	Medium

Overall, the most significant implementation risks are security control misconfiguration and disruption to legitimate business email, because either could directly affect the effectiveness of the security solution and create operational problems. These risks will be managed through phased deployment, controlled testing, configuration validation, monitoring, and corrective action.

The project's implementation methodology will therefore emphasize testing security controls before production deployment rather than implementing all controls simultaneously. This approach reduces the probability that an implementation error will affect the entire Yummy Pretzel Co. environment and supports the organization's ability to meet the project's security objectives.

This risk-management approach is consistent with the risk-management principles established by the NIST Cybersecurity Framework 2.0, which emphasizes identifying, assessing, managing, and continuously improving cybersecurity risk (Pascoe et al., 2024).

E. Training Approach

The training component will support the technical implementation by ensuring that employees understand how the new email security controls affect their daily activities and how to respond to suspected phishing attempts. Although employee training is an administrative control rather than a technology-supported security control, it is necessary to support the successful adoption of the technical solution.

Training Audience

Training will be provided to all 350 Yummy Pretzel Co. employees who use organizational email. Additional technical training will be provided to the IT, SOC, messaging, systems administration, and incident response teams responsible for operating and maintaining the security technologies.

Training Delivery

General employee training will be delivered through an online security awareness platform supplemented by instructor-led sessions for employees who require additional assistance. The organization will also conduct simulated phishing exercises to assess employees' ability to identify and report suspicious messages.

Technical personnel will receive vendor-specific training and hands-on configuration sessions covering the administration and monitoring of the implemented security technologies.

Training Content

Employee training will cover:

- Identifying phishing emails
- Recognizing suspicious attachments and links
- Identifying fraudulent business requests
- Verifying unexpected requests from external organizations
- Reporting suspected phishing messages
- Understanding email authentication indicators
- Proper handling of sensitive information
- Reporting suspected malware infections

Technical personnel training will cover:

- S/MIME administration
- SPF, DKIM, and DMARC configuration
- Secure Email Gateway administration
- EDR alert investigation
- Endpoint isolation
- Security event monitoring
- Incident escalation procedures

Training Duration

Initial employee training will consist of approximately **60 minutes** and will be completed before organization-wide deployment. Follow-up phishing simulations will occur quarterly. Technical administrators will receive approximately **four hours of hands-on technical training** before assuming operational responsibility for the implemented technologies.

F. Required Resources and Costs

The project requires personnel, technology, training, testing, and implementation resources.

Resource	Purpose	Estimated Cost	Cost Basis / Source
Microsoft Defender for Office 365 Plan 2	Phishing, malicious-link, and malicious-attachment protection; threat hunting and automated response	\$15,000/year	\$5/user/month × 250 users × 12 months. Microsoft publishes \$5/user/month for Plan 2. Microsoft Defender for Office 365: (Microsoft, n.d.)
Microsoft Defender for Endpoint Plan 2	Malware detection, endpoint monitoring, investigation, and device isolation	\$15,600/year	Budgetary estimate of \$5.20/user/month × 250 users × 12 months. Treat as an estimate unless a vendor quote is obtained. Microsoft Defender for Endpoint: (Microsoft, n.d.)
S/MIME certificates – DigiCert Secure Email for Employee	Email encryption and digital signatures	\$27,000/year	\$9/email address/month × 250 employees × 12 months. DigiCert publishes \$9/month for Secure Email for Employee. DigiCert S/MIME: (DigiCert, n.d.)
Microsoft Entra ID P1 / MFA	MFA, Conditional Access, identity and account protection	\$18,000/year	\$6/user/month × 250 users × 12 months. Microsoft publishes \$6/user/month; do not separately budget this if already included in Microsoft 365 Business Premium. Microsoft Entra ID: (Microsoft, n.d.)
KnowBe4 Security Awareness Training Advanced	Employee security awareness training and simulated phishing campaigns	\$8,880/year	\$2.96/user/month × 250 users × 12 months, using KnowBe4's published 251–500 seat Advanced rate.

			Published as a 3-year-term price. KnowBe4: (KnowBe4, 2026)
Security consultant	Technical implementation, configuration, and project assistance	\$14,000	Project estimate: 80 hours × \$175/hour. Identify as a budgetary labor estimate and support with the selected public rate source. KnowBe4: (KnowBe4, 2026)
Testing and validation resources	Phishing tests, malware testing, configuration validation, and security-control verification	\$5,000	Project budget estimate for lab/testing resources; not a vendor list price. KnowBe4: (KnowBe4, 2026)
Employee training delivery	Instructor time, training administration, and project-specific training materials	\$5,000	Project budget estimate for supplemental training delivery; separate from the KnowBe4 software subscription. KnowBe4: (KnowBe4, 2026)

Estimated First-Year Incremental Project Cost: \$105,480

Personnel Resources

The project will also require:

- Project Manager
- Information Security Manager
- SOC Analysts
- Systems Administrator
- Network Administrator
- Messaging Administrator
- Incident Response personnel
- External security consultant
- Email security vendor personnel

G. Final Project Deliverables

The project will produce several technical and administrative deliverables associated with the implementation of the layered email security solution.

1. Security Assessment Report

The report will document the original phishing incident, identify vulnerabilities, root causes, affected systems, and cybersecurity risks.

2. Technical Solution Design

The technical design will document the architecture and configuration requirements for:

- S/MIME
- SPF
- DKIM
- DMARC
- Secure Email Gateway
- EDR
- MFA
- Security monitoring

3. Implementation Documentation

The implementation documentation will describe the configuration and deployment of each security control.

4. Testing and Validation Report

The testing report will document the test cases, testing procedures, results, failed tests, corrective actions, and final validation results.

5. Training Materials

Training materials will include employee phishing-awareness content, phishing examples, reporting procedures, and simulation results.

6. Project Risk Register

The risk register will document implementation risks, their likelihood and impact, mitigation strategies, and risk owners.

7. Final Project Report

The final report will consolidate the project findings, implementation results, testing results, costs, timeline, stakeholder information, and recommendations for continuous improvement.

G1. Project Timeline

The project will be completed over approximately **24 weeks**.

Milestone	Duration	Start	End	Primary Resources
Project Initiation	2 weeks	11/02/2026	11/13/2026	Project Manager, CIO, Security Manager
Security Assessment	3 weeks	11/16/2026	12/04/2026	SOC, Security Manager, Systems Admin
Solution Design	3 weeks	12/07/2026	12/23/2026	Security Manager, Network Admin, Email Admin
Technical Configuration	4 weeks	01/04/2027	01/29/2027	Email Admin, Systems Admin, Vendor
Pilot Deployment	3 weeks	02/01/2027	02/19/2027	IT, SOC, Pilot Users
Organization-Wide Deployment	3 weeks	02/22/2027	03/12/2027	IT, SOC, Vendor
Testing & Validation	3 weeks	03/15/2027	04/02/2027	SOC, Security Manager, QA
Training & Transition	2 weeks	04/05/2027	04/16/2027	Security Team, HR, Employees
Project Closure	2 weeks	04/19/2027	04/30/2027	Project Manager, CIO, Security Manager

Projected Project End Date: April 30, 2027

H. Project Evaluation Approach

H1. Formative and Summative Test Plans

Formative Testing

Formative testing will occur throughout the implementation process rather than only after deployment.

Testing will include:

- Email authentication testing

- S/MIME certificate testing
- SPF validation
- DKIM validation
- DMARC validation
- Malicious attachment testing
- Email filtering testing
- EDR malware detection testing
- Endpoint isolation testing
- MFA authentication testing
- Security alert testing

Testing will initially occur in the controlled environment and pilot deployment before production implementation.

Summative Testing

Summative testing will occur after the complete solution has been deployed.

The project team will conduct controlled phishing simulations and technical security tests to determine whether the implemented solution can prevent, detect, and contain the attack scenario that originally affected Yummy Pretzel Co.

The final test will simulate the original attack chain:

Phishing Email → Malicious Attachment → Endpoint Execution → Malware Detection → Endpoint Isolation → Incident Alert

The objective will be to determine whether the layered controls prevent the attack from progressing through the same stages experienced during the original incident.

H2. Acceptance Criteria and Key Performance Indicators

The project will use measurable acceptance criteria to determine whether implementation is successful.

KPI	Target
Malicious email detection rate	$\geq 95\%$
Malicious attachment detection	$\geq 95\%$
EDR malware detection	100% of test malware
Endpoint isolation	≤ 5 minutes
MFA enrollment	100% of employees
SPF/DKIM/DMARC configuration	100%
Critical implementation vulnerabilities	0
Successful phishing simulation rate	$\leq 5\%$
Phishing reporting rate	$\geq 80\%$
Critical business disruption	0 incidents

The project will be considered successful when all mandatory technical controls have been implemented, critical test cases have passed, no critical unresolved vulnerabilities remain, and the acceptance criteria have been met or formally approved by the project sponsor.

H3. Justification of Test Cases and Scenarios

The test cases directly correspond to the attack experienced by Yummy Pretzel Co. The original incident began with a fraudulent email containing a malicious attachment. Therefore, the security solution must demonstrate that it can prevent or detect each stage of the attack.

Test Case 1: Spoofed Email

A simulated message will attempt to impersonate a legitimate external organization.

Purpose: Determine whether SPF, DKIM, DMARC, and email filtering identify the message as suspicious.

Test Case 2: Malicious Attachment

A controlled test attachment will be delivered to a test mailbox.

Purpose: Determine whether the Secure Email Gateway detects and blocks the attachment.

Test Case 3: Malware Execution

An approved malware simulation will be executed within an isolated test environment.

Purpose: Determine whether EDR detects the malicious behavior.

Test Case 4: Endpoint Isolation

A controlled endpoint compromise will be simulated.

Purpose: Determine whether EDR automatically isolates the affected endpoint.

Test Case 5: Credential Compromise

A simulated phishing credential request will be presented to a test user.

Purpose: Determine whether MFA prevents unauthorized access using compromised credentials.

Test Case 6: Phishing Simulation

A controlled phishing campaign will be sent to participating employees.

Purpose: Measure employee interaction and reporting rates.

These tests are justified because they directly reproduce the key attack characteristics that led to the original security incident.

H4. Results Analysis

The project team will compare testing results against the established baseline and acceptance criteria. Results will be analyzed using quantitative measurements such as detection percentage, false-positive rate, false-negative rate, endpoint isolation time, phishing interaction rate, and phishing reporting rate.

For example, if the baseline phishing simulation interaction rate is 25% and the post-implementation rate decreases to 5%, the project team can determine whether the combination of technical controls and training produced the desired improvement.

Failed test cases will be documented and assigned to the appropriate technical stakeholder for remediation. The test will then be repeated to determine whether the corrective action resolved the identified issue.

The final evaluation will compare pre-implementation and post-implementation results to determine whether the project achieved its objectives. The results will be presented to the project sponsor and the Information Security Manager before project closure.

I. Sources and References

Cybersecurity and Infrastructure Security Agency. (2024, September 25). *CISA warns of hurricane-related scams*. [CISA](#)

Dawkins, S., & Jacobs, J. (2023). *NIST Phish Scale user guide* (NIST Technical Note 2276). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.TN.2276>

DigiCert. (n.d.). *Buy secure email (S/MIME) certificates*. Retrieved August 18, 2026, from <https://www.digicert.com/tls-ssl/secure-email-smime-certificates>

DigiCert. (n.d.). *Compare secure email (S/MIME) certificates*. Retrieved August 18, 2026, from <https://www.digicert.com/tls-ssl/compare-secure-email-smime-certificates>

KnowBe4. (2026). *Security awareness training pricing*. Retrieved August 18, 2026, from <https://www.knowbe4.com/products/security-awareness-training/pricing>

Microsoft. (2025). *Microsoft Digital Defense Report 2025*. [Microsoft Digital Defense Report 2025](#)

Microsoft. (n.d.). *Microsoft Defender for Office 365*. Retrieved August 18, 2026, from <https://www.microsoft.com/en-us/security/business/siem-and-xdr/microsoft-defender-office-365>

Microsoft. (n.d.). *Microsoft Defender for Endpoint*. Microsoft Learn. Retrieved August 18, 2026, from <https://learn.microsoft.com/en-us/defender-endpoint/supported-capabilities-by-platform>

Microsoft. (n.d.). *Microsoft Entra ID*. Retrieved August 18, 2026, from <https://www.microsoft.com/en-us/security/business/identity-access/microsoft-entra-id>

National Institute of Standards and Technology. (2020). *Security and privacy controls for information systems and organizations* (NIST Special Publication 800-53 Rev. 5). <https://doi.org/10.6028/NIST.SP.800-53r5>

National Institute of Standards and Technology. (2025, April 3). *NIST revises SP 800-61: Incident response recommendations and considerations for cybersecurity risk management*. [NIST](#)

Pascoe, C., Quinn, S., & Scarfone, K. (2024). *The NIST Cybersecurity Framework (CSF) 2.0* (NIST Cybersecurity White Paper 29). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.CSWP.29>

Verizon. (2025). *2025 Data breach investigations report*. [Verizon 2025 Data Breach Investigations Report](#)